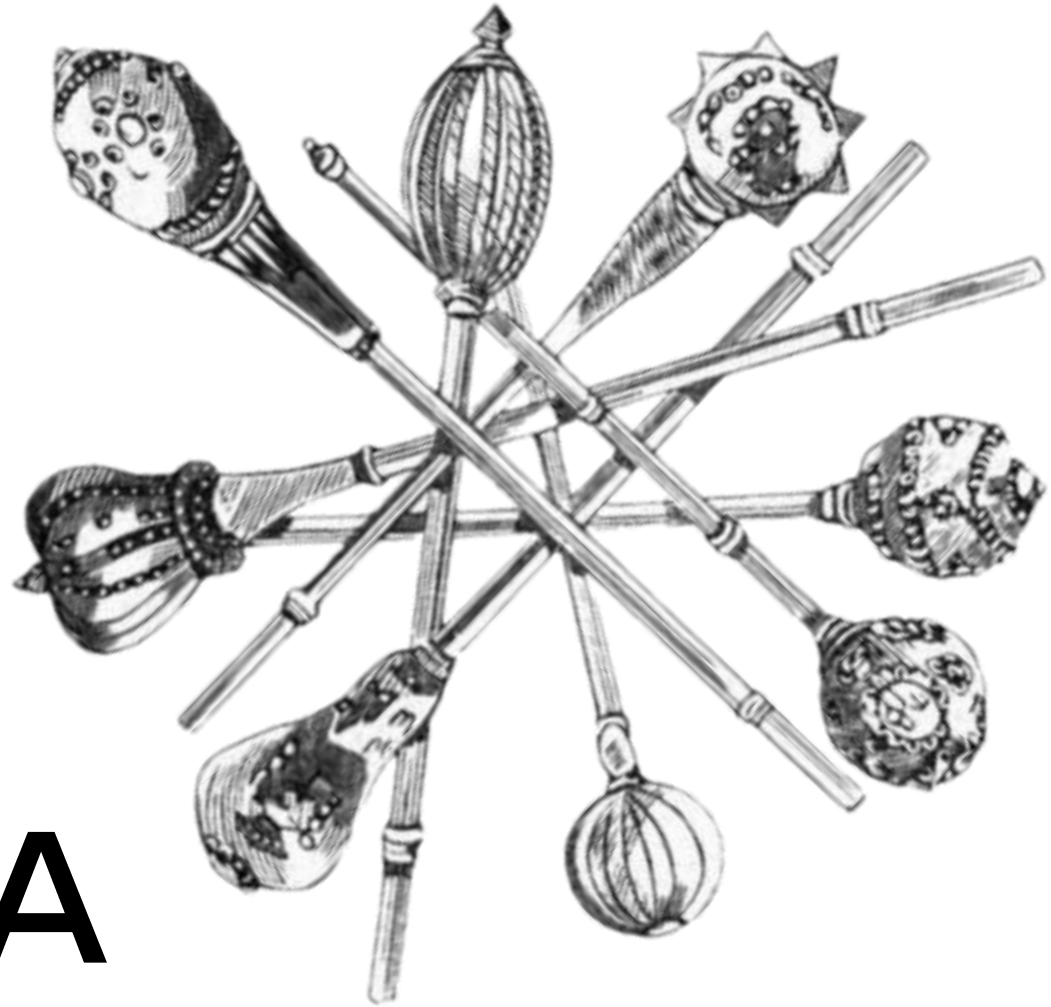
GRC101: ПРОФЕСІЙНА ОРІЄНТАЦІЯ



ДАВАЙТЕ ПОЗНАЙОМИМОСЬ

Іван Гокін

IT-аудитор, CISA, 5+ років досвіду в консалтингу та аудиті

ЩО МИ ОБГОВОРИМО

- Визначення
- Перспективність
- Необхідні навички
- Інструменти
- Процес
- Кого почитати

ВИЗНАЧЕННЯ

- Governance (Врядування) – забезпечення спроможності організації досягати бізнес-цілей
- Risk (Управління ризиком) – стійкість організації відносно внутрішніх та зовнішніх чинників
- Compliance (Відповідність) – відповідність вимогам законодавства, третіх сторін тощо



GRC - це інтегрований набір можливостей, які дозволяють організації досягти принципової продуктивності - здатності надійно досягати цілей, вирішувати невизначеність і діяти чесно.

oceg

ЩО ТАКЕ СИСТЕМИ УПРАВЛІННЯ?

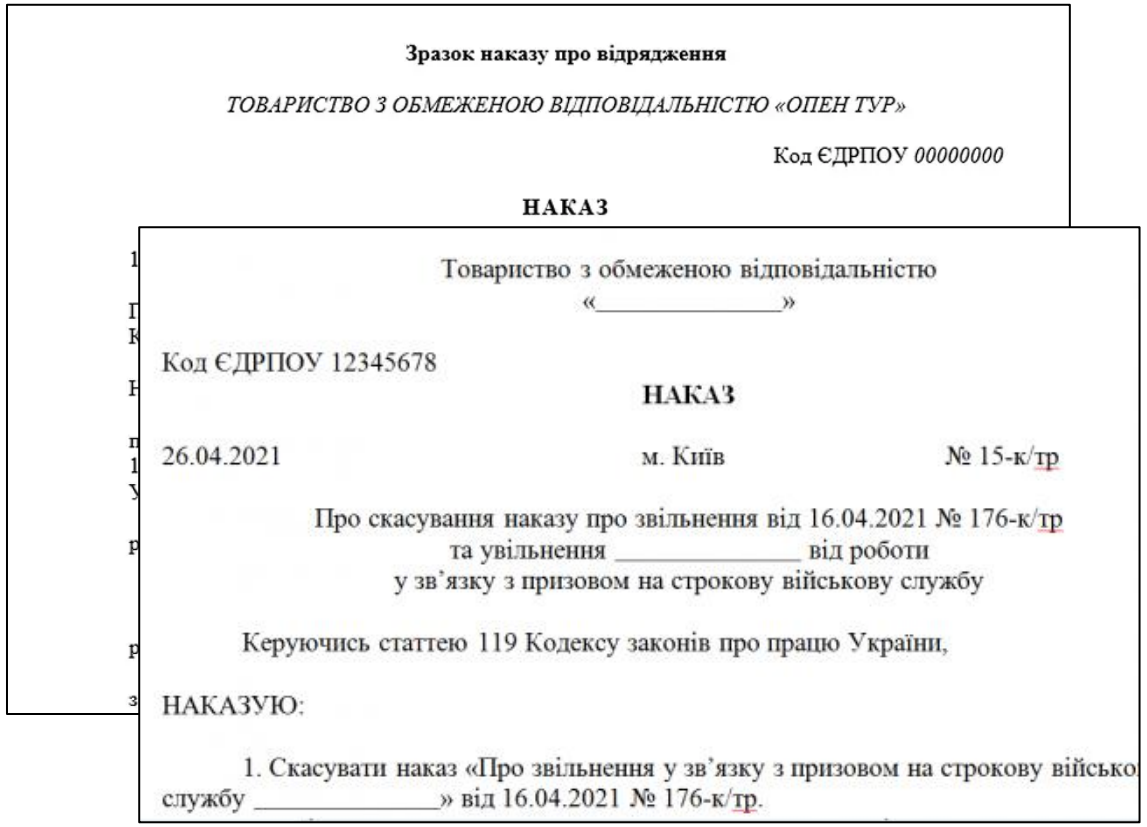
ISO 9001:2015

Сукупність взаємопов'язаних або взаємодіючих елементів організації для встановлення намірів і цілей, а також процесів для досягнення цих цілей.



НАКАЗИ, УКАЗИ, ПАПЕРИ….

- Самі по собі накази теж є системою управління
- Без процесного підходу тим не менш вони не є надійним способом управління
- Як наступний керівник знатиме про всі чинні накази?



Зразок наказу про відрядження

ТОВАРИСТВО З ОБМЕЖЕНОЮ ВІДПОВІДАЛЬНІСТЮ «ОПЕН ТУР»

Код ЄДРПОУ *00000000*

НАКАЗ

Товариство з обмеженою відповідальністю
«_____»

Код ЄДРПОУ 12345678

НАКАЗ

26.04.2021 м. Київ № 15-к/тр

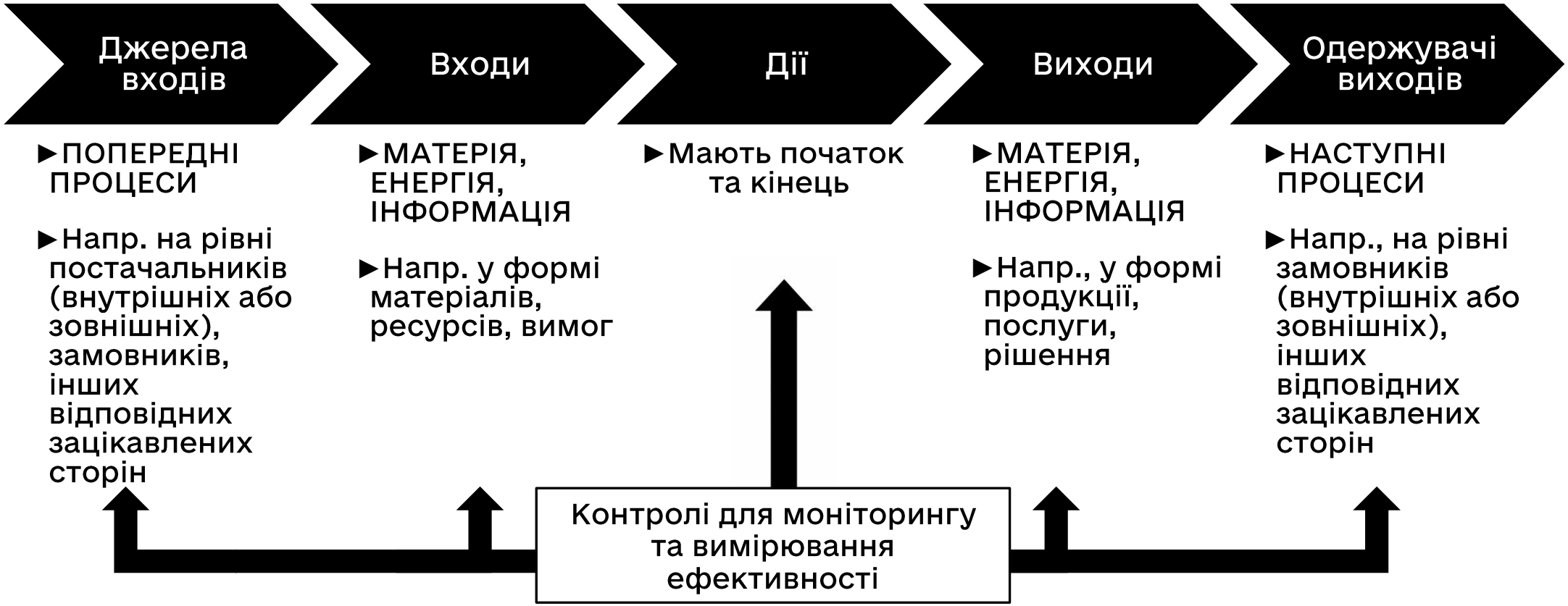
Про скасування наказу про звільнення від 16.04.2021 № 176-к/тр
та увільнення _____ від роботи
у зв'язку з призовом на строкову військову службу

Керуючись статтею 119 Кодексу законів про працю України,

НАКАЗУЮ:

1. Скасувати наказ «Про звільнення у зв'язку з призовом на строкову військову службу _____» від 16.04.2021 № 176-к/тр.

СИСТЕМИ УПРАВЛІННЯ – ОСНОВА ПРОЦЕСНОГО ПІДХОДУ



Джерело: ДСТУ ISO/IEC 9001:2015

ТИПИ СИСТЕМИ УПРАВЛІННЯ НА ПРИКЛАДІ ISO

Стандарти системи управління

- ISO 9001:2015 Quality management systems — Requirements
- ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements
- ISO 14001:2015 Environmental management systems — Requirements with guidance for use

Галузеві стандарти системи управління

- ISO 13485:2016 Medical devices — Quality management systems — Requirements for regulatory purposes
- ISO 22163:2023 Railway applications — Railway quality management system — ISO 9001:2015 and specific requirements for application in the railway sector

Стандарти, що відносяться до систем управління, та настанови з впровадження

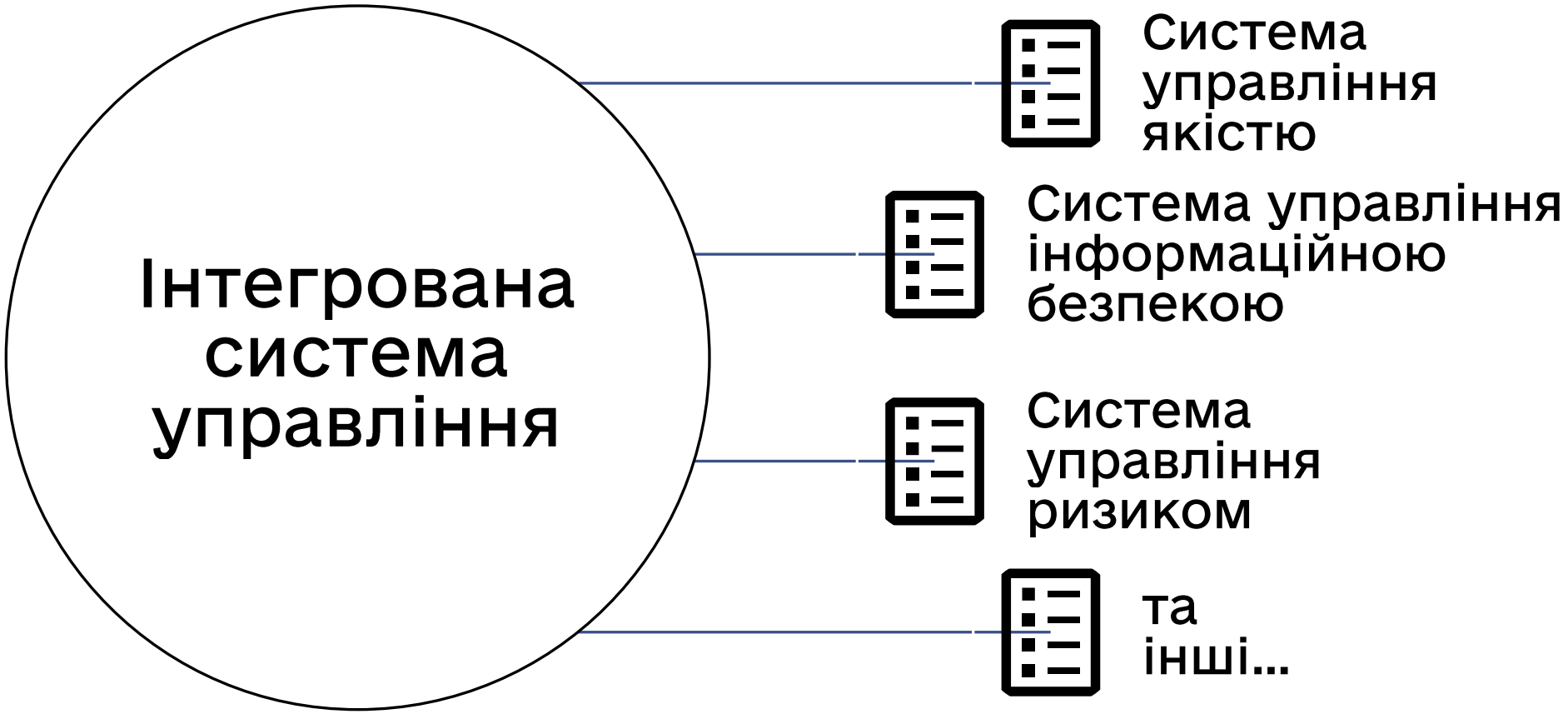
- ISO 45003:2021 Occupational health and safety management — Psychological health and safety at work — Guidelines for managing psychosocial risks
- ISO 19011:2018 Guideline managements for auditing systems

Стандарти управління

- ISO 26000:2010 Guidance on social responsibility
- ISO 31000:2018 Risk management — Guidelines

Джерело: iso.org
В Україні стандарти ISO зазвичай адаптуються як ДСТУ Прибрати їх можна, наприклад, в **ДП «УКрНДНЦ»**

ІНТЕГРОВАНА СИСТЕМА УПРАВЛІННЯ ПОЄДНУЄ СИСТЕМИ УПРАВЛІННЯ



ЯК ПОБУДУВАТИ СУІБ



ВИЩЕ КЕРІВНИЦТВО ПОВИННО ПРОДЕМОНСТРУВАТИ ДІЇ З УПРАВЛІННЯ ТА ЗОБОВ'ЯЗАННЯ ПО ВІДНОШЕННЮ ДО СУІБ

- Гарантуванням, що політика інформаційної безпеки та цілі інформаційної безпеки розроблені та сумісні зі стратегічними планами організації
- Гарантуванням інтеграції вимог СУІБ в процеси організації
- Гарантуванням, що ресурси, потрібні для СУІБ, доступні
- Призначенням та підтримкою осіб для досягнення ефективності СУІБ
- Сприянням постійному вдосконаленню
- Доведенням до відома організації важливості ефективного управління інформаційною безпекою та відповідності вимогам СУІБ
- Гарантуванням, що СУІБ досягне своїх запланованих результатів
- Підтримкою інших пов'язаних ролей вищого керівництва, щоб продемонструвати їх керівну роль, яку вони застосовують у сферах їх відповідальності.

Джерело: ISO/IEC 27001

СИСТЕМУ УПРАВЛІННЯ ІБ МОЖНА БУДУВАТИ НА РІЗНИХ СТАНДАРТАХ

COBIT
An ISACA Framework

NIST
CYBERSECURITY FRAMEWORK

NIST
SP 800-53
LOW BASELINE

PCI

International Organization for Standardization
ISO
27001

CIS Center for Internet Security

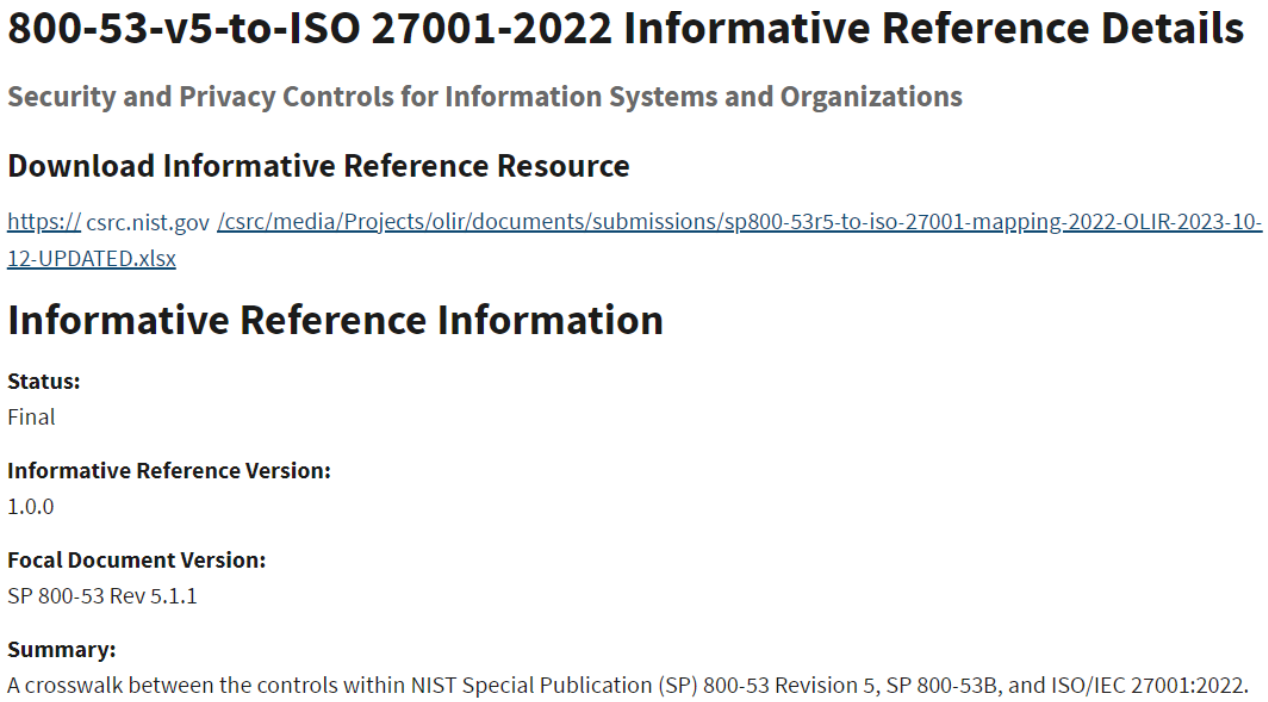
NIST
SP 800-53
HIGH BASELINE



Але яка ж родина стандартів буде кращим варіантом?

ВИБІР ОДНОГО СТАНДАРТУ ДЛЯ ПОБУДОВИ СУІБ НЕ ПРОТИРІЧИТЬ ВИКОРИСТАННЮ ІНШИХ

- Стандарти співвідносяться один з одним так званими mapping / crosswalk
- Приклад співвідношення стандартів ISO/IEC 27001 та NIST SP 800-53 від NIST.



800-53-v5-to-ISO 27001-2022 Informative Reference Details

Security and Privacy Controls for Information Systems and Organizations

Download Informative Reference Resource

https:// csrc.nist.gov /csrc/media/Projects/olir/documents/submissions/sp800-53r5-to-iso-27001-mapping-2022-OLIR-2023-10-12-UPDATED.xlsx

Informative Reference Information

Status:
Final

Informative Reference Version:
1.0.0

Focal Document Version:
SP 800-53 Rev 5.1.1

Summary:
A crosswalk between the controls within NIST Special Publication (SP) 800-53 Revision 5, SP 800-53B, and ISO/IEC 27001:2022.

ЯКИМИ МАЮТЬ БУТИ ПОЛІТИКИ ТА ІНШІ ВНД



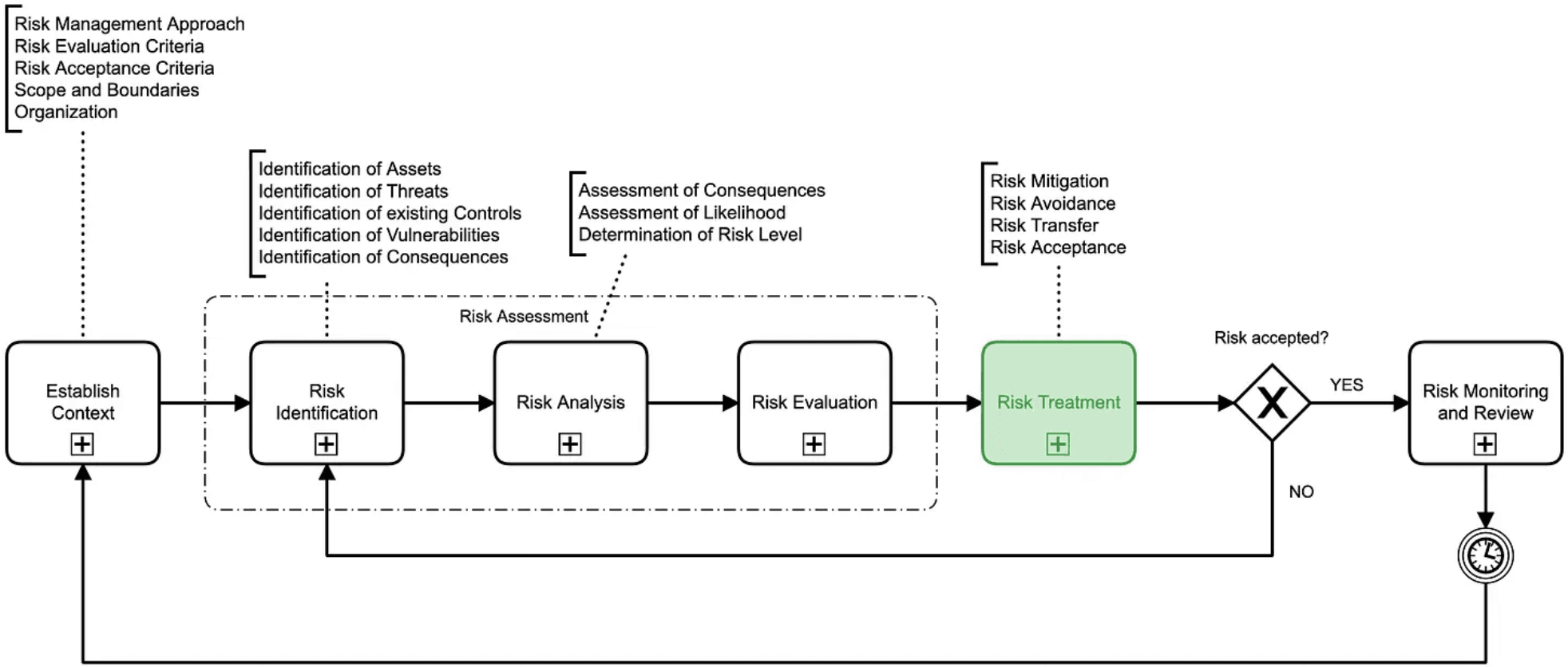
Гарна практика - це мати «політику-про-політики», яка описуватиме стандартний шаблон, шлях погодження подібних документів.

Бажані якості політики:
- Потрібна
- Затверджена
- Зрозуміла
- Лаконічна
- Стандартно структурована
- Регулярно переглядається
- Доступна

Політики ІБ в банках (напр.)

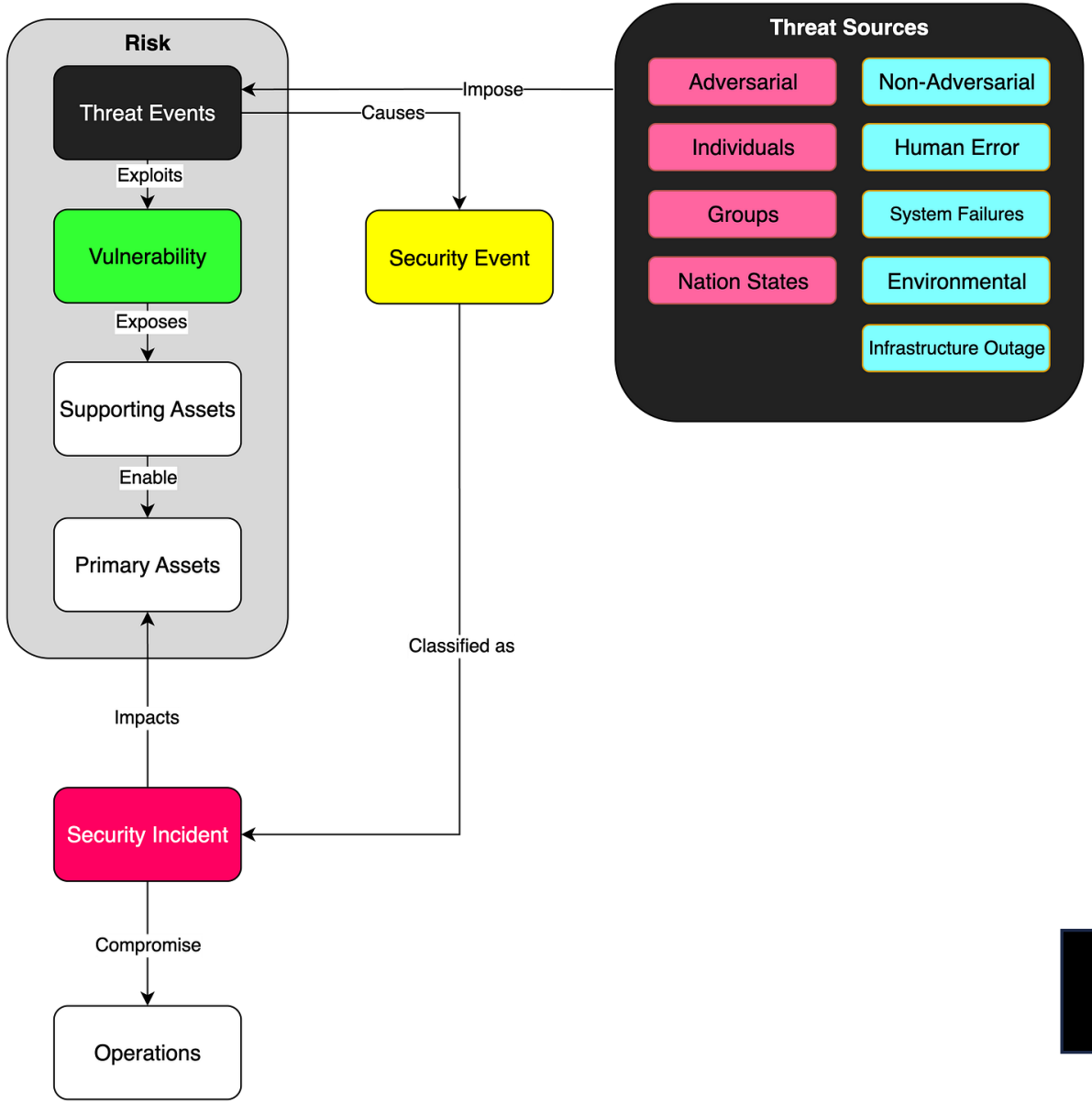
Хочете навчитись писати гарні політики?

ПРОЦЕС УПРАВЛІННЯ РИЗИКАМИ



ПОДІЇ РИЗИКУ

- Розуміння того, що таке ризик – у всіх різне
- Перед наповненням створіть політику управління ризиками та поради власникам ризиків



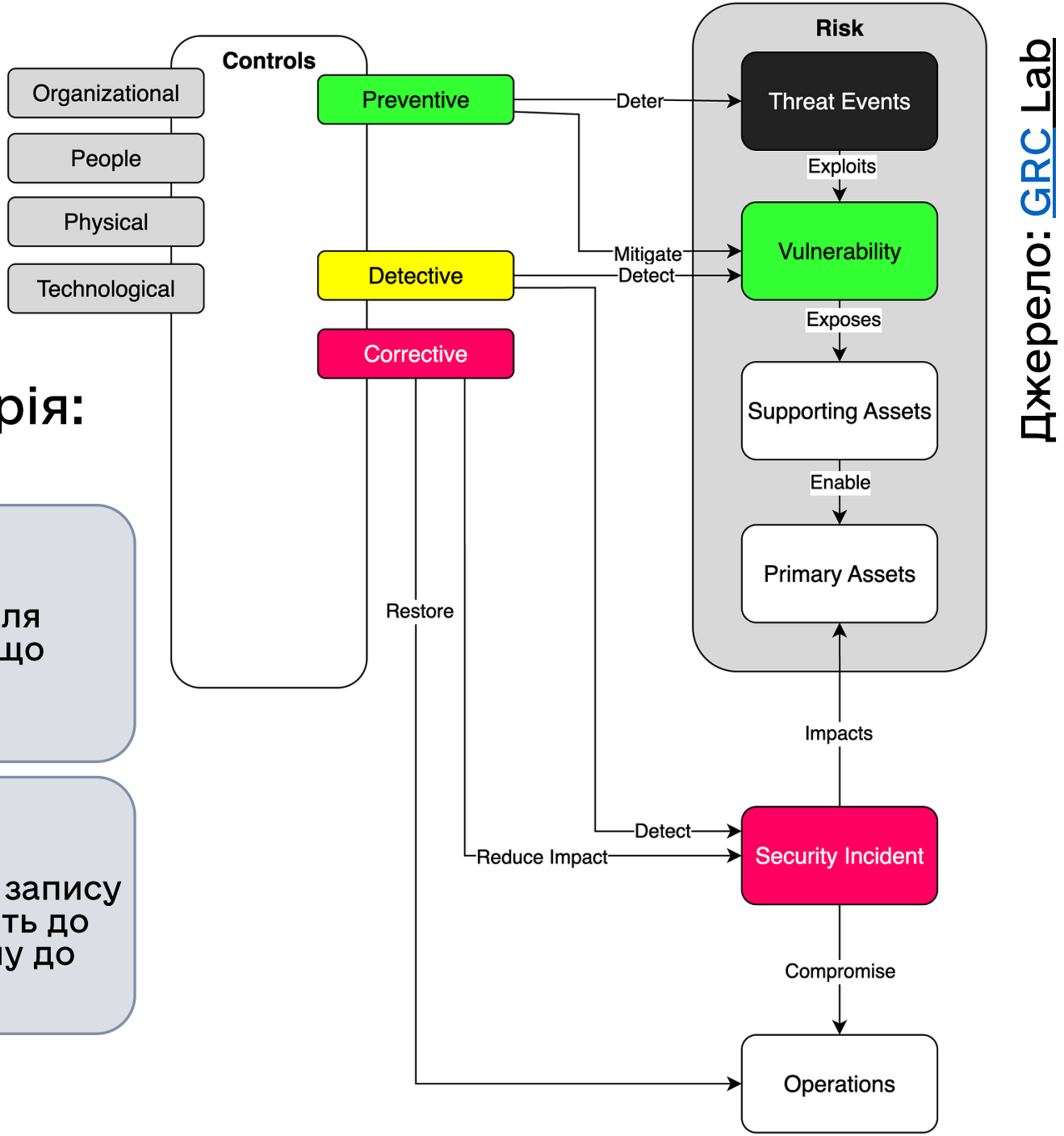
Джерело: GRC Lab

CTI vs. Risk Management

КОНТРОЛІ

► Дайте шаблон сценарія:

ШАБЛОН СЦЕНАРІЯ	Зловмисник експлуатує [вразливість / слабкість] для того, щоб [виконати дію], що призводить до [наслідку].
ПРИКЛАД	Зловмисник експлуатує відсутність MFA для компрометації облікового запису користувача, що призводить до несанкціонованого доступу до конфіденційних даних



Джерело: GRC Lab

РЕЄСТР РИЗИКІВ

►Зафіксуйте ролі та відповідальності: ви – ризик-координатор, а не власник ризику. Іншими словами, якщо ризик реалізується, платити буде власник, тому і рішення приймати має він.



ЗІБРАЛИ РИЗИКИ, ТРЕБА ОЦІНИТИ

- Для оцінки ризиків важливо мати розуміння того, як це може вплинути на актив та на організацію.
- Також важливо розуміти наскільки такий сценарій ймовірний. Для цього можна взяти інформацію з розвідки кіберзагроз.
- Неправильно сформульований сценарій ризику зведе нанівець оцінку ризиків.



ПОШИРЕНА ПРОБЛЕМА

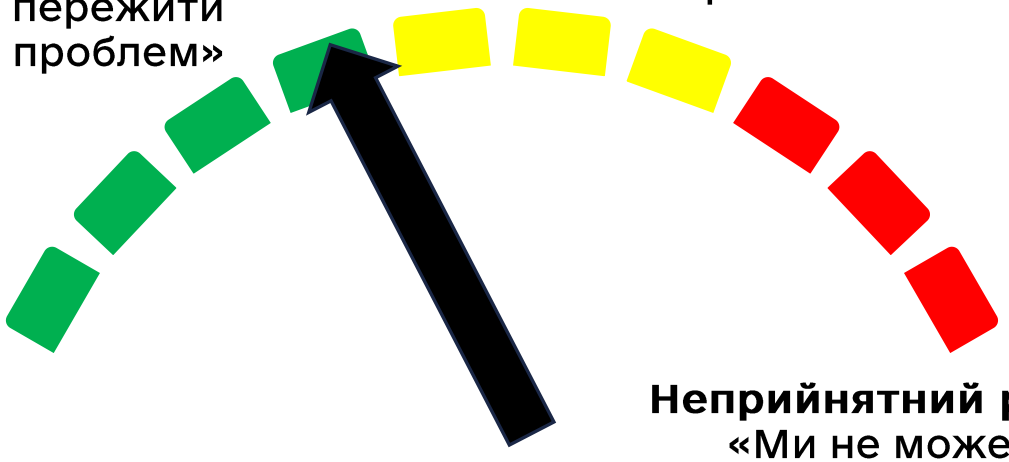


Фахівці з управління ризиком мають модерувати реєстр ризиків та адекватність його оцінки, та підважувати це рішеннями вищого керівництва, інакше він не несе ніякої цінності.

РИЗИК АПЕТИТ

Ризик апетит
«Ми можемо це пережити без проблем»

Прийнятний ризик
«Ми можемо це пережити»



Неприйнятний ризик
«Ми не можемо це пережити»



"My 35 years of experience tell me your tolerance for risk is low..."

ЩО ЩЕ ВАРТО ПАМ’ЯТАТИ

- Ризик-апетит допомагає відсіювати незначні для нас ризики.
- Користь будь-якої оцінки ризиків вимірюється корисними та зрозумілими рішеннями та контролями.
- Вплив ризиків можна рахувати в грошах (див. методологію FAIR).
- Моделювання загроз допомагає формувати реєстр ризиків (див. Фреймворки моделювання загроз OCTAVE, PASTA).
- Управління ризиками йде рука в руку з забезпеченням неперервності бізнесу та іншими подібними дисциплінами.

ВІДПОВІДНІСТЬ



ДЖЕРЕЛА ВИМОГ

Міжнародні договори, закони Євросоюзу	17
→Закони України	11
→→Укази Президента України	4
→→Постанови Кабінету Міністрів України	43
→→Накази Адміністрації Держспецзв'язку	43
→→Накази СБУ	1
→→Постанови Національного банку України	7
Протоколи НКЦК	1
Стандарти та політики НАТО	32
НД ТЗІ	56
ВСТ	5
ДСТУ	3

Деталі

ІНТЕГРАЦІЯ ВИМОГ ЗАКОНУ ДОПОМАГАЄ ЗМЕНШУВАТИ ВИТРАТИ НА КОМПЛАЄНС

ПОШИРЕНА ПРАКТИКА



ІНТЕГРОВАНІ СИСТЕМИ УПРАВЛІННЯ

- ►«Політика GDPR»+вимоги щодо захисту даних+посадові обов’язки визначають DPO
- ►Доведення вимог під підпис виконавцям
- ►Документи скоріше задля зняття відповідальності ніж для їх подальшого використання

- ►Політика захисту персональних даних
- ►Виконавці працюють тільки з описаним процесом
- ►Вимоги законодавства інтегруються в процеси

ЯК ІНТЕГРОВУВАТИ ВИМОГИ ЗАКОНІВ

- Закони можна співвідносити зі стандартами систем управління
- Оскільки це теж свого роду тлумачення, бажано спиратись на такі ж меппінги з боку регуляторів або галузевих асоціацій

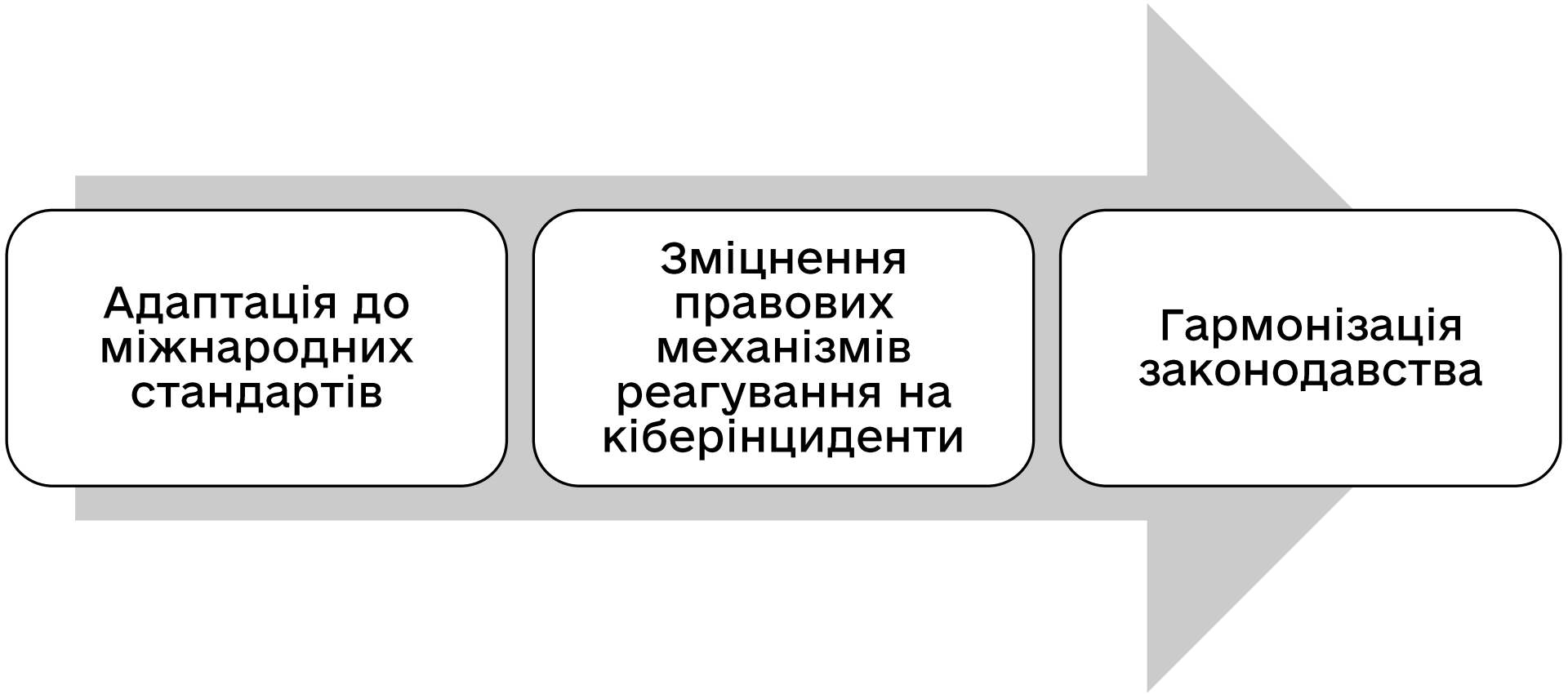
ID	DORA	Requirement	NIS2 IT Act	C5:2020	ISO 27001 2022
D.17	Art. 17	Incident management	3.1.1 3.1.2 3.1.3	SIM-01 SIM-02 SIM-03 SIM-04 SIM-05 COS-01	A.5.24 A.5.25 A.5.26 A.5.28 A.6.8
D.18	Art. 18	Classification of incidents and cyber threats	3.4.1 3.4.2	SIM-01	A.5.25
D.19	Art. 19	Incident and Cyber Threat Reporting	3.3.1 3.3.2	OIS-05 SIM-01 SIM-04	A.5.5 A.5.6 A.6.8
D.23	Art. 23 23	Handling payment or safety incidents	- -	- -	- -
D.45	Art. 45	Exchange of information and insights into cyber threats	4.3.3 6.10.2	OIS-05	A.5.5 A.5.6

Tabelle: *Own compilation - as of March 2025 - Without guarantee of completeness and correctness*

ЗАКОНИ НЕ ТІЛЬКИ ЗОБОВ'ЯЗУЮТЬ НАС, АЛЕ І ЗАХИЩАЮТЬ

Розділ XVI КРИМІНАЛЬНИЙ КОДЕКС УКРАЇНИ	**Ст.361.** Несанкціоноване втручання в роботу інформаційних (автоматизованих), електронних комунікаційних, інформаційно-комунікаційних систем, електронних комунікаційних мереж.
	Ст.362. Несанкціоновані дії з інформацією, яка оброблюється в електронно-обчислювальних машинах (комп'ютерах), автоматизованих системах, комп'ютерних мережах або зберігається на носіях такої інформації, вчинені особою, яка має право доступу до неї.
	Ст.363. Порушення правил експлуатації електронно-обчислювальних машин (комп'ютерів), автоматизованих систем, комп'ютерних мереж чи мереж електрозв'язку або порядку чи правил захисту інформації, яка в них оброблюється.

НАПРЯМКИ ПОДАЛЬШОГО РОЗВИТКУ ЗАКОНОДАВСТВА УКРАЇНИ



ЧИМ ДОПОМАГАЄ НАМ СУДОВА ПРАКТИКА?

Тлумачення закону буває різне, тому важливо досліджувати судову практику та думки регуляторів для того, щоб правильно тлумачити та впроваджувати вимоги закону і уникнути штрафів або інших проблем.

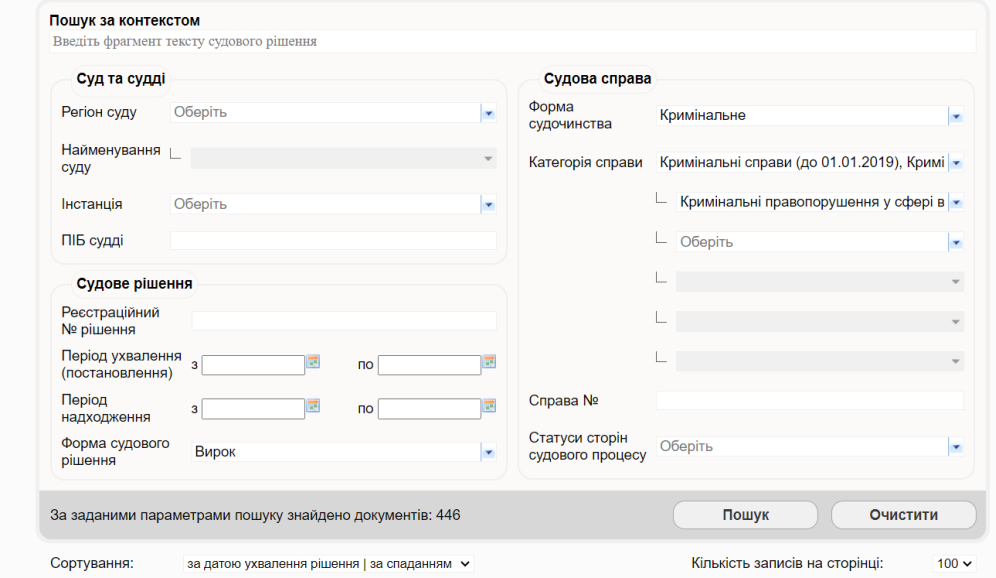
ЯК ЗНАЙОМИТИСЬ З СУДОВОЮ ПРАКТИКОЮ

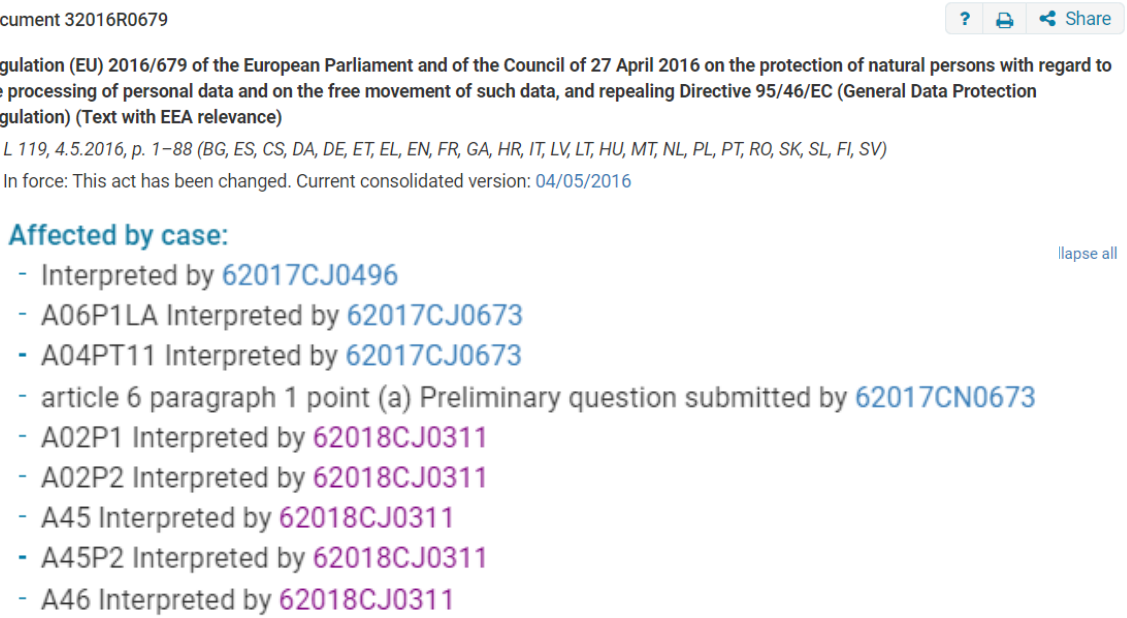
УКРАЇНА

ЄВРОСОЮЗ

[РЕЄСТР СУДОВИХ РІШЕНЬ]

[В ТЕКСТІ ЗАКОНУ]

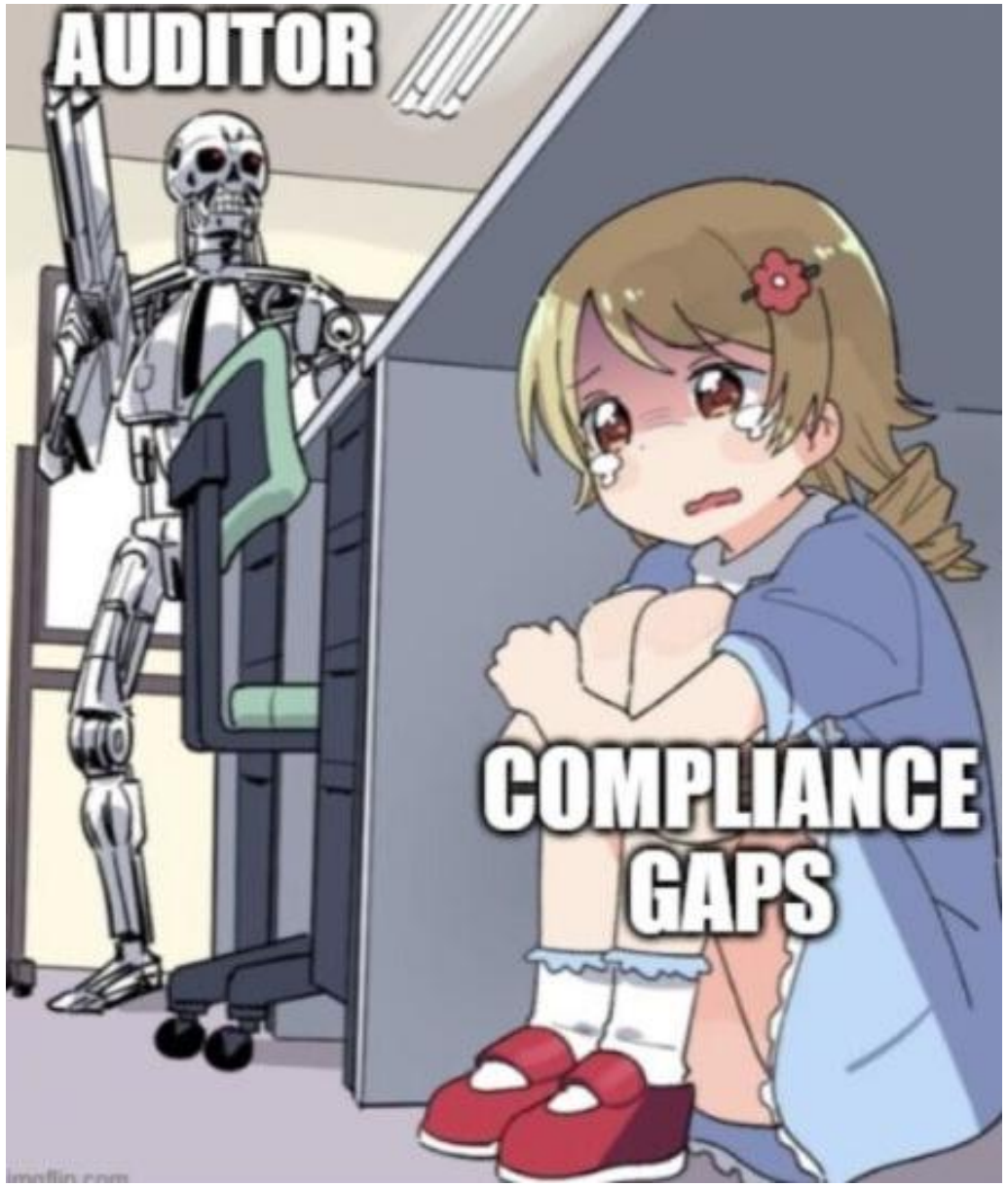




ЩО ТАКЕ АУДИТ?

Аудит – це офіційна перевірка того, чи дотримуються стандарту або набору керівних принципів, чи є записи точними, чи досягаються цільові показники ефективності та результативності.

© Глосарій ISACA

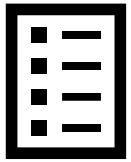


ЩО ТАКЕ АУДИТ?

ПРИЗНАЧЕННЯ



Продемонструвати відповідність закону



Виконати вимоги контрагентів (постачальників, клієнтів)



Отримати незалежну оцінку ефективності роботи СУІБ

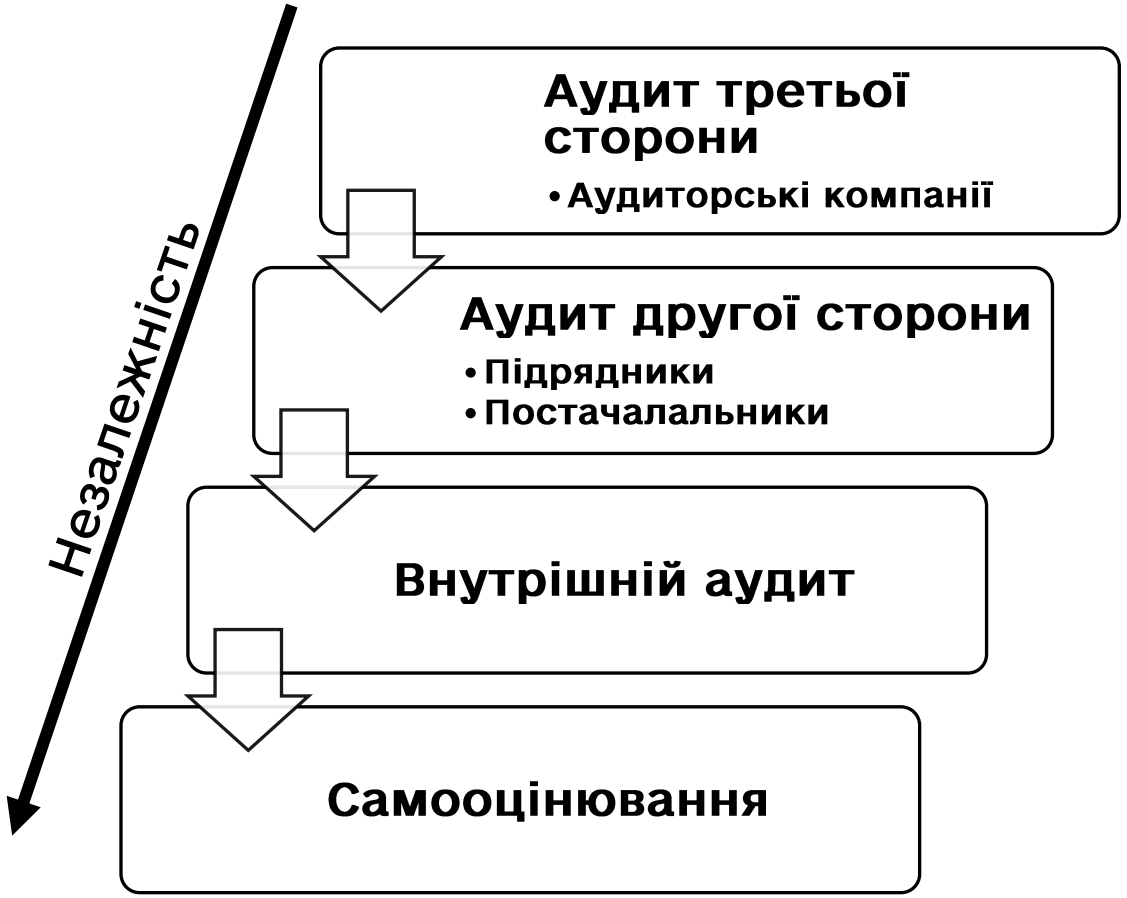
ОСНОВНІ ЯКОСТІ

Незалежність

Доказовість

Об’єктивність

РІВНІ НЕЗАЛЕЖНОСТІ АУДИТОРА



Незалежність - свобода від обставин, що загрожують об’єктивності чи створюють враження об’єктивності. Необхідно, щоб такі загрози об’єктивності нейтралізувалися на рівні окремого аудитора, завдання і на функціональному та організаційному рівнях.

Незалежність включає в себе незалежність у поглядах та незалежність у проявах.

© ITAFv3

НЕЗАЛЕЖНІСТЬ АУДИТОРА ПІДТРИМУЄТЬСЯ ПРОФЕСІЙНОЮ РЕПУТАЦІЄЮ ТА ЗАКОНОМ

Закон України

«Про аудит фінансової звітності та аудиторську діяльність»

Добра репутація аудитора - репутація, за якої протягом двох років поспіль до аудитора не застосовувалося стягнення три і більше разів або не накладалися адміністративні стягнення за порушення вимог цього Закону двічі протягом 12 календарних місяців.

Конфлікт інтересів - суперечність між особистими майновими, немайновими інтересами аудитора (посадових осіб аудиторської фірми) та його професійними правами і обов'язками, наявність якої може вплинути на об'єктивність або неупередженість під час виконання ним своїх професійних обов'язків, а також на вчинення чи невчинення ним дій.

Професійна таємниця аудитора - інформація (матеріали, документи, інше), що стала відома аудитору в процесі надання аудиторських послуг [....]

АУДИТОРСЬКІ КОМПАНІЇ МОЖУТЬ НЕСТИ ВІДПОВІДАЛЬНІСТЬ ЗА АУДИТОРСЬКІ ВИСНОВКИ ЗА ЗАКОНОМ

Аудиторський висновок - офіційний висновок фахівця з аудиту та підтвердження довіри до ІС, що описує обсяг аудиту, процедури, які застосовувалися для підготовки звіту, а також те, чи підтверджують результати відповідність критеріям аудиту.

© ITAFv3

безумовний висновок	не встановлено жодних порушень, або жодне із встановлених порушень не призводить у сукупності до значного порушення;
обмежений висновок	вказує на порушення, які у сукупності призводять до значного порушення, але яке не є суттєвим недоліком;
негативний висновок	встановлює одне чи кілька значних порушень, які у сукупності призводять до суттєвого недоліку



►До 2001 року існувала «велика п'ятірка» аудиторських фірм.

►Arthur Andersen, заснована в 1913 році в Чикаго, протягом 90 років була однією з найуспішніших аудиторських компаній світу.

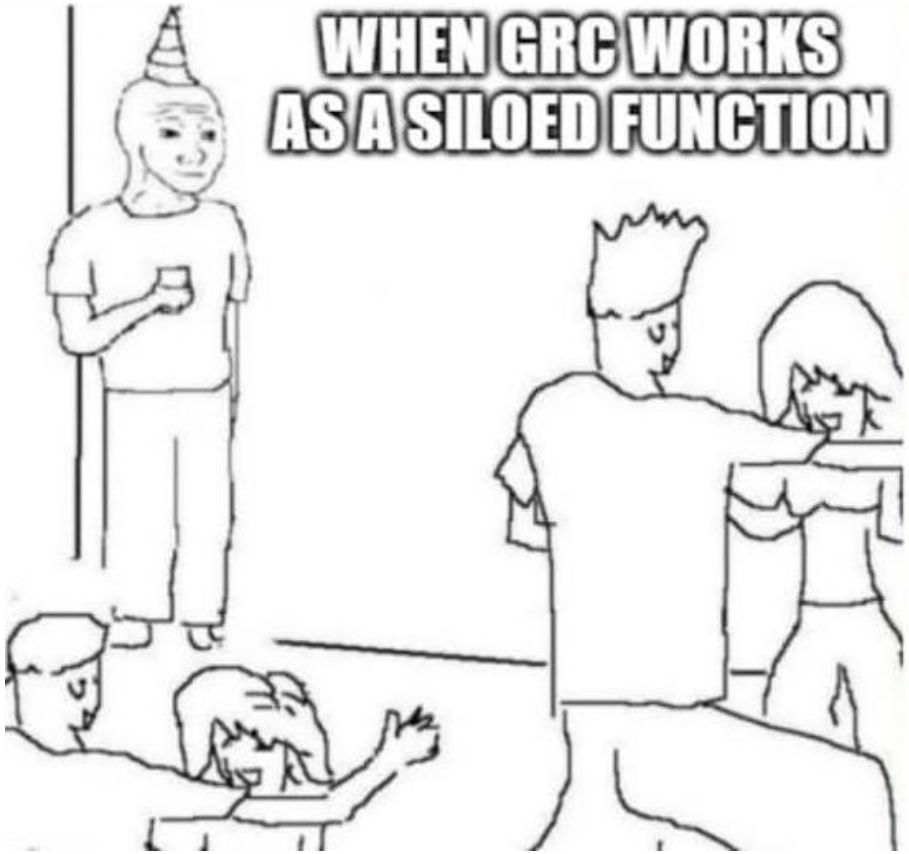
►І найбільшим клієнтом х'юстонського офісу Arthur Andersen був Enron, який сплачував за свій аудит до $20 млн на рік, і стільки ж – за консалтинг.

►Зваживши всі ризики і переваги, аудитори банально не захотіли втрачати такого клієнта, і готували такий висновок, яким його хотіли бачити в Enron, навіть коли помічали невідповідність у звітності. А потім співробітники Arthur Andersen і взагалі стали знищувати документи.

ЯК ЦЕ ВСЕ СТОСУЄТЬСЯ КІБЕРБЕЗПЕКИ?

GRC підрозділ окрім прямо покладених на нього обов'язків допомагає:

- ►Впровадити мінімально необхідний набір контролів кібербезпеки
- ►Злагоджувати внутрішню політику, різницю в думках та інтересах
- ►Обгрунтовувати інвестиції в нові інструменти кібербезпеки та / або розширення штату
- ►Узгоджувати бачення проблем та пріоритетів бізнесу і кібербезпеки



ПЕРСПЕКТИВНІСТЬ

ОСНОВНІ РОБОТОДАВЦІ

- **Регульовані галузі** (критична інфраструктура, енергетика, банки, державний сектор) потребують впроваджену СУІБ згідно з вимогами закону
- **Експортно-орієнтовані компанії** (напр. ІТ аутсорсинг) хочуть мати впроваджену СУІБ згідно з вимогами клієнта
- **Продуктові компанії** бажають мати впроваджену СУІБ для забезпечення довіри з боку користувачів

СПІЛЬНОТА

- Медіана зп «Security» 2000$/міс. (dou.ua)
- Сотні фахівців в Україні (144+ в ISACA Kyiv)
- 28+ вакансій станом на зараз
- Євроінтеграція, розвиток вимог до критичної інфраструктури та штучного інтелекту, переорієнтація на експорт **розвиватимуть попит**

НЕОБХІДНІ НАВИЧКИ - CYBER LEGAL, POLICY & COMPLIANCE OFFICER

Основні завдання	Забезпечення відповідності законодавству у сфері захисту даних та конфіденційності Виявлення прогалин у compliance та розробка політик і процедур Проведення оцінок впливу на конфіденційність (DPIA) Навчання персоналу та формування культури захисту даних Взаємодія з регуляторами, партнерами та внутрішніми командами Аудит кібербезпеки та управління юридичними аспектами ІБ
Ключові навички	Застосування принципів захисту даних у бізнес-процесах Розробка та впровадження политик кібербезпеки Проведення оцінок впливу на конфіденційність Комунікація з зацікавленими сторонами Відстеження змін у законодавстві та адаптація стратегії
Ключові знання	Законодавство та нормативні акти з кібербезпеки Стандарти та фреймворки ІБ (ISO 27001, NIST, GDPR) Політики кібербезпеки Методології оцінки впливу на приватність

European Cybersecurity Skills Framework

ОСНОВНІ СЕРТИФІКАЦІЇ - CYBER LEGAL, POLICY & COMPLIANCE OFFICER

- Certified Information Security Manager (CISM)
- Certified Information Systems Auditor (CISA)
- ISO/IEC 27001 Auditor / Implementer
- NIST Cybersecurity Framework Auditor / Implementer

З фокусом на майбутнє також

- Certified GRC Engineer – Practitioner
- Професійний стандарт Держспецзв'язку: «Фахівець з планування політики та стратегії кібербезпеки»

Деталі

ЯК ДУМАЄТЕ, ЧАСТО ТАКЕ ТРАПЛЯЄТЬСЯ?



МАЙБУТНЄ ЗА GRC ENGINEERING

ПРОБЛЕМИ ТРАДИЦІЙНОГО GRC

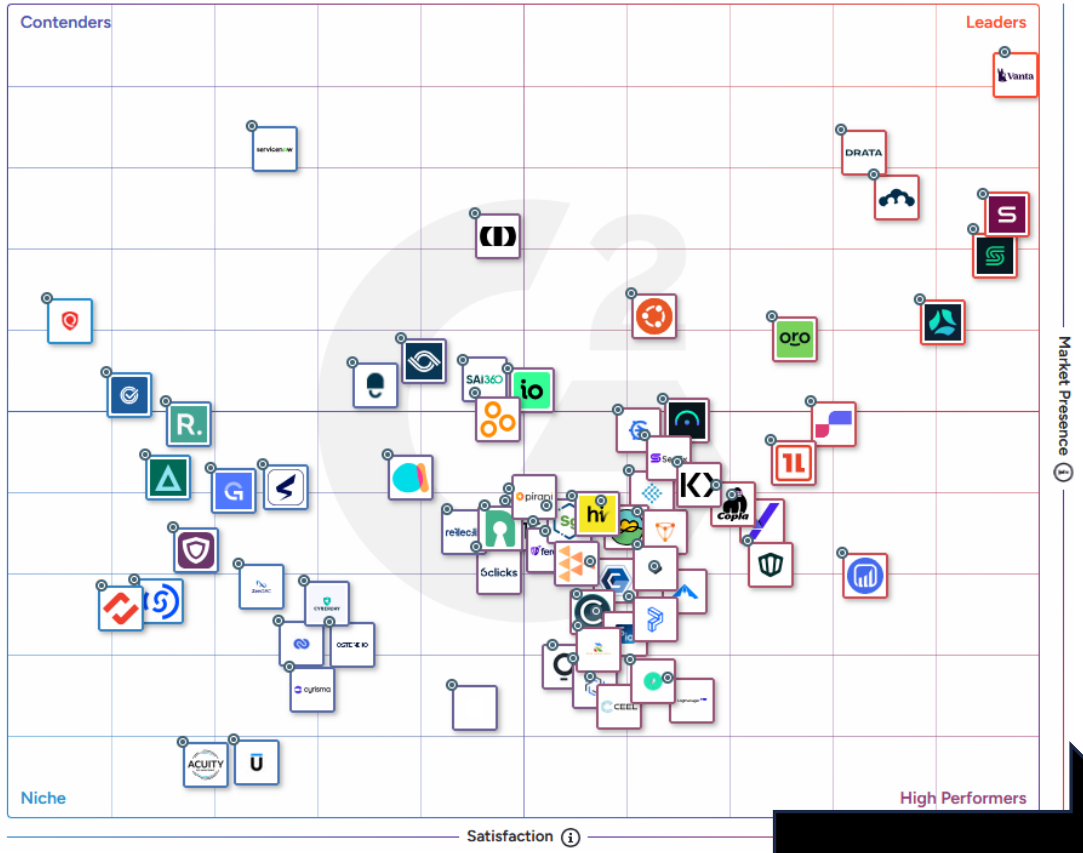
- ►Ручна праця та слабкі результати
- ►Транзакційні відносини зі стейкхолдерами
- ►Мислення категорією симптомів, а не причин
- ►Сліпа віра у фреймворки
- ►Compliance як формальність

ПРИНЦИПИ СУЧАСНОГО GRC

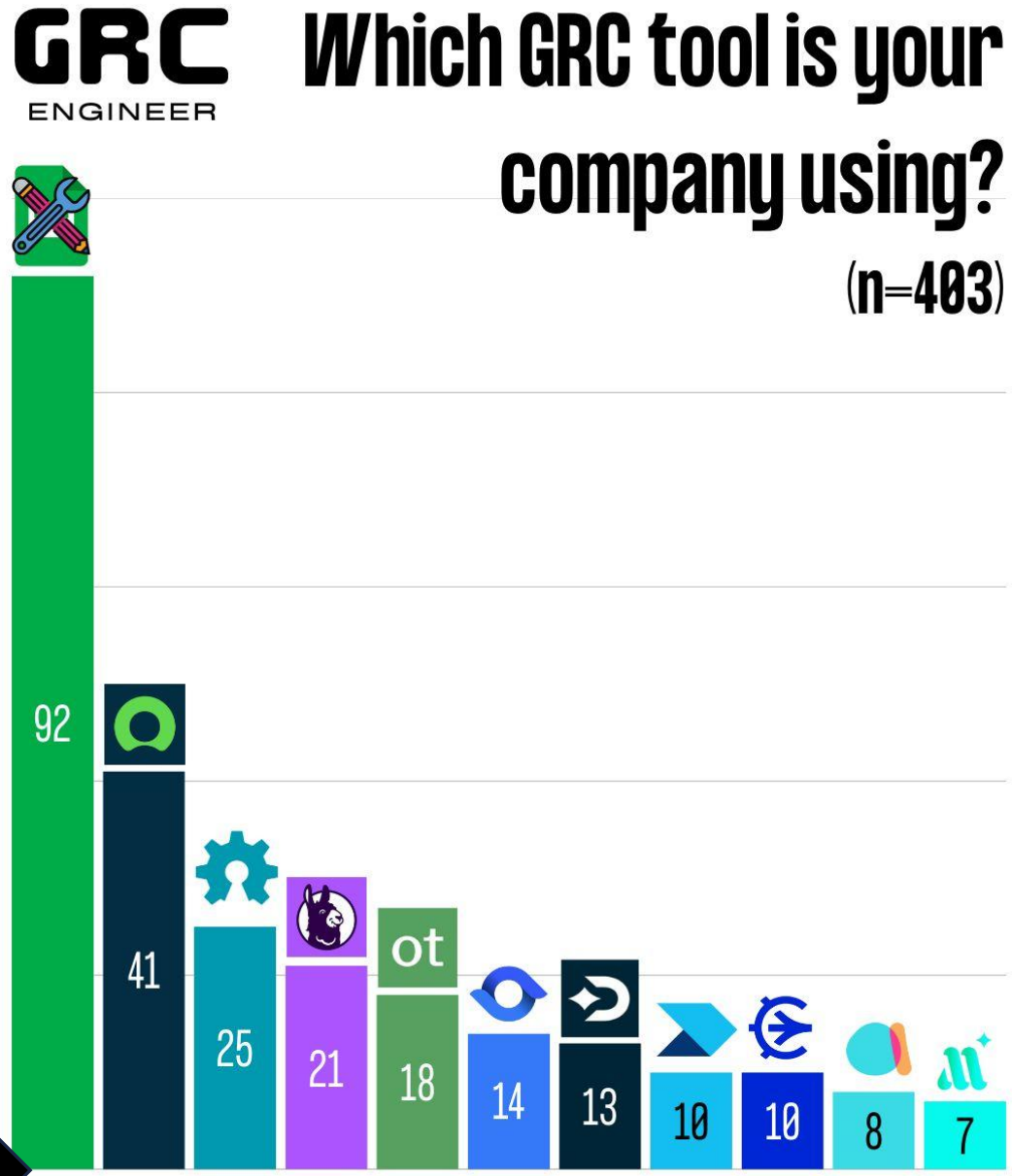
- ►Shift GRC left
- ►GRC як продукт
- ►Threat-informed GRC
- ►Системне + дизайн-мислення
- ►Відкрита спільнота практиків

Деталі

ІНСТРУМЕНТИ



Деталі



ПІДСУМОК

ЩО ТАКЕ GRC

GRC-підрозділ допомагає організації:

►Виходити на нові ринки та відповідати вимогам законодавства.

►Впровадити мінімально необхідний набір контролів — без зайвого

►Вирішувати внутрішні конфлікти інтересів і узгоджувати пріоритети

►Обґрунтовувати інвестиції в інструменти та людей

►Зблизити бачення бізнесу та кібербезпеки

ПЕРСПЕКТИВИ

►Фахівці з GRC вже добре представлені на ринку України.

►Кількість фахівців буде тільки рости з євроінтеграцією та адаптацією NIS2, DORA, GDPR, розвитком ШІ та зростанням ІТ-експорту та ІТ-продуктів в Україні.

►**Майбутнє — за GRC Engineering**

►Автоматизація та ШІ забирають рутину — і відкривають місце для технічно підкованих фахівців, які вміють будувати системи, а не лише заповнювати таблиці.



Містобудівні ігри наглядно демонструють принаймні частину ідей, які закладаються в GRC.



КОГО ПОЧИТАТИ

- GRC Engineering: Ayoub Fandi
- GRC Destroyer – критичний погляд на галузь
- Управління ризиками: Tony Ridley, Dr. Serhii Babych
- Відповідність: Kai Zenner (ЄС)